

Compliance – Consent, POPIA & GDPR

Voice and likeness are personal – and biometric – data. **POPIA** (South Africa, your base) and **GDPR** (UK/EU, your target markets) both require informed, express, *recorded* consent before processing, plus purpose limitation, retention limits, and data-subject rights. Once a real person's face or voice enters the system, this is non-negotiable. Build it in from Iteration 1 even though GAS ticks consent on behalf of subjects for now – the structure has to be right so productization doesn't require a retrofit.

Express consent at the point of upload

Whenever a user uploads a **photo** or a **voice file** (Build Me, or any real-likeness use), **block the action until explicit consent is captured**. Not pre-ticked, not bundled into one box — discrete, affirmative checkboxes the user must actively tick:

- ☐ I confirm I have the right to use this person's image / voice.
- ☐ I consent to creating an AI likeness / voice clone from this material.
- ☐ I understand the purpose: producing marketing video content for {client}.
- ☐ I understand consent can be withdrawn and the data deleted at any time.

On submit, write a consent record (below). "For now we tick as the agency" means `granted_by` is the GAS user acting for the subject — the same record structure later carries the subject's own consent without change.

What every consent records

- subject identity (name; email optional)

- data type (image | voice)
- scope / purpose of processing
- lawful basis (consent , or contract where that applies)
- the exact **consent-text version** shown at the time
- granted_by (which user) and on whose behalf
- **timestamp** — date + time + timezone (the audit requirement under both laws)
- status (active | withdrawn),
withdrawn_at
- linked influencer / asset

Compliance tab (the register)

A read-only audit view listing every consent: subject, type, scope, lawful basis, granted_by, **timestamp**, status. Filterable by client / influencer, and **exportable (CSV/PDF)** as your record of processing. This is the screen you put in front of an auditor or a client's legal team.

Data-subject rights & retention

- **Withdrawal / erasure.** Withdrawing consent — or deleting an influencer or brain — must purge the source upload, the derived assets in Blob, AND call the providers' delete endpoints (ElevenLabs voice, HeyGen avatar, Higgsfield Soul) so the clone doesn't live on upstream. Log the deletion with a timestamp.
- **Retention.** Set a default retention window; don't keep biometric source files longer than the purpose needs.
- **Access.** The Compliance tab + export satisfies subject-access requests.

Schema

```
create table consent_texts (  
  id          uuid primary key default  
    gen_random_uuid(),  
  version     int not null,  
  body        text not null,  
  -- the exact wording shown
```

```

    effective_from timestampz default
now(),
    active      boolean default true
);

create table consents (
    id          uuid primary key
default gen_random_uuid(),
    client_id    uuid references
clients(id),
    influencer_ref text,
-- linked influencer/asset
    subject_name text not null,
    subject_email text,
    data_type    text not null,
-- 'image' | 'voice'
    scope       text not null,
    lawful_basis text not null
default 'consent',
    consent_text_id uuid not null
references consent_texts(id),
    granted_by    uuid not null
references users(id),
    granted_at    timestampz not
null default now(), -- date + time
+ tz
    status       text not null
default 'active', -- 'active' |
'withdrawn'

```

```
    withdrawn_at    timestampz  
);
```

Iteration 2 note

When external customers self-serve, the **subject** should grant consent directly (or upload documented authorisation), and each tenant gets its own register. The model already supports this — `granted_by` simply moves from the agency user to the subject, and the Compliance tab scopes by tenant.